

TAREA HE01

Pautas de seguridad informática

Autor: Carlos España Del Pozo - CETI

Contenido

Detalles de la tarea de esta unidad	3
Apartado 1: Diseñar el plan de auditoría	3
Respuestas 1	4
Apartado 2: Organiza las fases de la auditoría	5
Respuestas 2	6
Apartado 3: Presentación y valoración de vulnerabilidades	8
Respuestas 3	8

Detalles de la tarea de esta unidad

Caso práctico

Innovatech Solutions es una empresa tecnológica española en plena expansión, con una plantilla de 150 empleados. Se especializa en el desarrollo de software a medida que utiliza inteligencia artificial (IA) para optimizar la cadena de suministro de empresas de logística. Su software gestiona datos críticos de sus clientes, como rutas de transporte, inventarios y datos de destinatarios finales.

Una vez han completado la creación del nuevo departamento de "Seguridad Ofensiva" y Juan, junto con su equipo han finalizado las sesiones de formación. Teresa les reúne para asignarles su primer cometido.

Teresa les comenta que el primer cometido del equipo es diseñar un plan de auditoría para este primer trimestre. Dado que es la primera vez que se enfrentan a un reto de estas características ha acordado con la dirección que este primer trimestre les realizará la auditoría una empresa externa. Además, el presupuesto asignado para este trimestre sólo permite que se realicen un máximo de 3 auditorías

El equipo de Juan tiene que diseñar el tipo de auditorías que se realizará teniendo en cuenta las siguientes premisas:

- **Disponen de un total de 20 activos expuestos a internet entre servidores web, servidores de correo, acceso VPN.**
- **De estos 20 activos, 3 de ellos se consideran críticos para el negocio**
- **Además, también les interesa realizar una primera revisión de la red interna.**

Apartado 1: Diseñar el plan de auditoría

Teniendo en cuenta las premisas y restricciones indicadas por Teresa diseñar el plan de auditoría. Como mínimo tienes que plantear y explicar las siguientes cuestiones y razonar correctamente tu elección:

- Justificar la elección de cada auditoría elegida.
- Justificar los activos incluidos en cada auditoría.
- Indicar en cada caso el tipo de auditoría dependiendo del enfoque, origen e información proporcionada y justifica cada caso
- Indica el objetivo que quieres conseguir con la elección de cada tipo de auditoría.

Respuestas 1

Una vez revisada la información al respecto y para poder diseñar el plan de auditoría, consideramos los activos críticos, los riesgos asociados y el objetivo de asegurar tanto la disponibilidad como la integridad y confidencialidad de los sistemas.

<i>Nombre de la Auditoría</i>	<i>Justificación de la Auditoría</i>	<i>Activo(s) y justificación</i>	<i>Enfoque</i>
Auditoría de Servidores Web	Los servidores web están expuestos a Internet y representan un punto crítico de entrada para atacantes.	Servidores web (parte de los 20 activos expuestos a Internet). objetivo descubrir vulnerabilidades que se pudieran encontrar en el perímetro externo de la compañía.	Test de intrusión
Auditoría de Servidores de Correo	El correo es un posible activo crítico y uno de los principales vectores de ataque externo.	Servidores de correo expuestos a Internet para operación del negocio. Objetivo descubrir vulnerabilidades que se pudieran encontrar en el perímetro externo además de realizar un análisis de madurez del sistema de correo para futuros ataques de phishing	Auditoria con pruebas manuales
Auditoría de Accesos VPN y Red Interna	La VPN da acceso directo a la red corporativa, por lo que comprometerla implica acceso al entorno interno. Se realizará también una primera revisión de la red interna.	Acceso VPN y red interna perimetral. objetivo descubrir vulnerabilidades que un atacante podría localizar si se encontrase dentro de la red local de la compañía	Auditoría con pruebas automáticas

<i>Nombre de la Auditoría</i>	<i>Origen</i>	<i>Información proporcionada</i>	<i>Objetivo</i>
Auditoría de Servidores Web	Auditoría con pruebas externas	Auditoría con pruebas de caja gris. Información de servidores web, autenticación, conectividad y usuarios. excepción en el firewall para realizar la auditoría	Detectar vulnerabilidades en los servidores web, evitar compromisos que puedan afectar a servicios críticos.
Auditoría de Servidores de Correo	Auditoría con pruebas externas	Auditoría con pruebas de caja gris. Información de servidores de correo, autenticación, conectividad y usuarios. excepción en el firewall para realizar la auditoría	Detectar las posibles vulnerabilidades en los servicios de imap y smtp, además de reducir riesgo de suplantación, fuga de información y accesos indebidos.
Auditoría de Accesos VPN y Red Interna	Auditoría con pruebas internas	Auditoría con pruebas de caja blanca. Listado de accesos VPN y 2FA, políticas de acceso, topología de red interna, segmentación de la red, direccionamientos.	Detectar debilidades en accesos remotos y validar seguridad de la red interna para evitar movimientos laterales y accesos indebidos

Apartado 2: Organiza las fases de la auditoría

Una vez has planteado las auditorías que realizarías, es necesario que indiques para cada una de ellas un calendario (o timeline) en el que se refleje los hitos de cada una de las fases con estimaciones de tiempo:

- Utiliza un calendario o línea temporal para indicar cuándo se realizaría cada fase y el tiempo estimado.
- Indica los objetivos a cumplir en cada fase.
- Justifica para cada auditoría si se contemplan reuniones de seguimiento o no, en caso afirmativo cada cuánto tiempo.

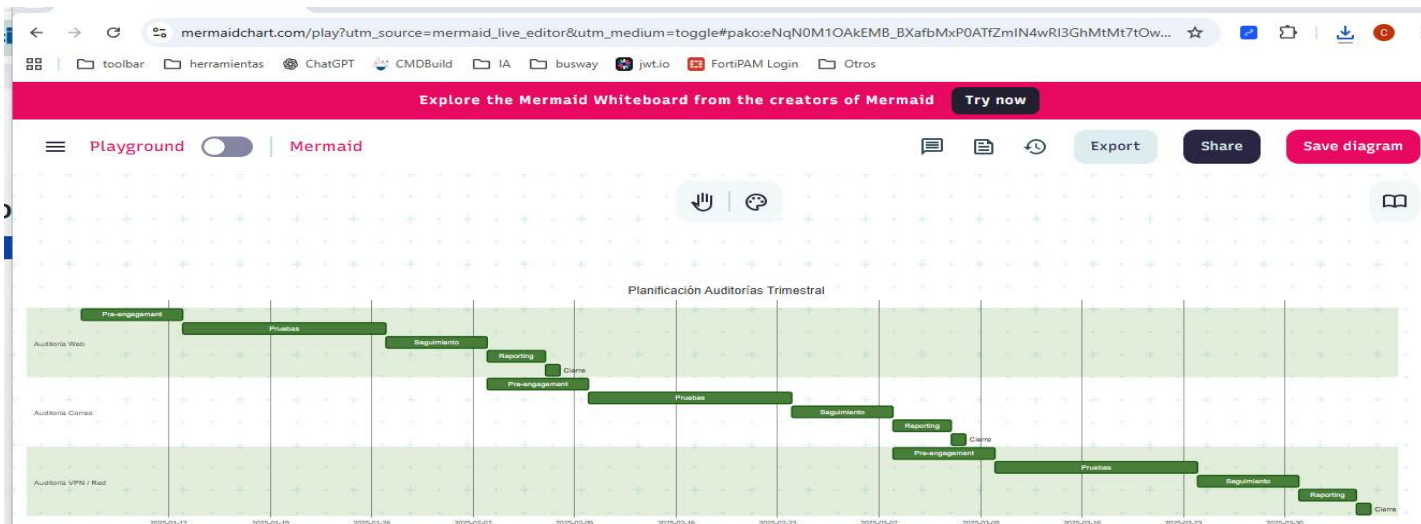
Respuestas 2

A continuación, detallo el calendario con fases de cada auditoría

<i>Auditoría</i>	<i>Duración Estimada</i>	<i>Toma de requisitos Pre-engagement (duración / objetivo)</i>	<i>Realización de pruebas (duración / objetivo)</i>	<i>Seguimiento (duración / objetivo)</i>
Auditoría de Servidores Web	4 semanas	1 semana / Analizar infraestructura web, puntos de entrada y servicios expuestos	2 semanas / Reconocimiento de activos a auditar, detección y explotación de las vulnerabilidades	1 semana / Se comunicarán al cliente los hallazgos localizados desde la reunión anterior y se contrasta con equipo técnico
Auditoría de Servidores de Correo	4 semanas	1 semana / Recopilar información de arquitectura, protocolos y políticas de correo	2 semanas / Reconocimiento de activos de correo SMTP/IMAP, detectar vulnerabilidades y pruebas de phishing interno controlado	1 semana / Se confirmará el itinerario y siguientes pasos en la auditoría/pruebas
Auditoría de Acceso VPN y Red Interna	4 semanas	1 semana / Identificación de accesos, arquitectura y segmentación de red	2 semanas / Se realizan técnicas para poder aumentar el nivel de privilegios en la red y los sistemas, acceder a otros activos internos, ejecutar técnicas que nos brinden acceso secundario sin tener que volver a explotar la vulnerabilidad	1 semana / Se confirmará el itinerario y siguientes pasos en la auditoría/pruebas

<i>Auditoría</i>	<i>Reporting (duración / objetivo)</i>	<i>Cierre (duración / objetivo)</i>	<i>Reuniones de seguimiento</i>
Auditoría de Servidores Web	4 días / Elaborar informe final con la metodología, el alcance, objetivos y un resumen de vulnerabilidades y recomendaciones de los activos webs.	1 día / Presentación de los resultados y se entra en detalle en vulnerabilidades de gravedad más crítica, se presentan recomendaciones para solventar cada una de las vulnerabilidades localizadas.	Reunión inicial, semanal y final

Auditoría de Servidores de Correo	4 días / Elaborar informe final con la metodología, el alcance, objetivos y un resumen de vulnerabilidades y recomendaciones del correo electrónico.	1 día / Presentación de los resultados y se entra en detalle en vulnerabilidades de gravedad más crítica, se presentan recomendaciones para solventar cada una de las vulnerabilidades localizadas.	Reunión inicial, semanal y final
Auditoría de Acceso VPN y Red Interna	4 días / Elaborar informe final con la metodología, el alcance, objetivos y un resumen de vulnerabilidades y recomendaciones de la red local y los accesos VPN.	1 día / Presentación de los resultados y se entra en detalle en vulnerabilidades de gravedad más crítica, se presentan recomendaciones para solventar cada una de las vulnerabilidades localizadas.	Reunión inicial, semanal y final



Apartado 3: Presentación y valoración de vulnerabilidades

- Valoración de la vulnerabilidad especificando los grupos de métricas base y temporal. Además, indica el vector CVSS resultante, realizar capturas de pantalla de los valores indicados.
- Es muy importante justificar vuestra elección en los puntos del formulario CVSS.
- Justificar si es una vulnerabilidad que afecta al servidor o a los clientes.
- **Las vulnerabilidades localizadas son las siguientes.**
 - Una vulnerabilidad en el sistema de correo de la compañía que permite tomar el control del servidor y acceder a los mensajes de correo de cualquier usuario, también puedes enviar correos electrónicos suplantando la identidad de los usuarios. El servidor de correo se encuentra expuesto en internet. La vulnerabilidad presenta tanto un exploit público accesible desde exploit-db como un parche propuesto por el fabricante.
 - Una vulnerabilidad de inyección SQL en la que se pueden consultar datos de otras Bases de Datos como la Base de Datos de Contabilidad. El servidor web está expuesto en internet, pero se requiere de un usuario para el acceso a la funcionalidad vulnerable. No es una vulnerabilidad conocida, el auditor la localizó en tiempo de auditoría.
 - Una vulnerabilidad de ejecución remota de código en un servidor FTP en la red interna de la organización. El servicio FTP se estaba ejecutando con privilegios del sistema (puede realizar cualquier acción en el sistema). Además, el acceso al servidor permite acceder a una subred de administración que no se encuentra accesible desde la red LAN de usuarios. Existe un parche público para corregir la vulnerabilidad. No hay exploit público, pero sí una prueba de concepto que el auditor ha tenido que modificar para poder explotar de manera correcta la vulnerabilidad.

Respuestas 3

Dividiremos el análisis en las vulnerabilidades de la siguiente manera:

Vulnerabilidad en el correo

Acceso total al servidor de correo y suplantación de usuarios. Afecta al servidor y, por extensión, a todos los clientes.

Permite leer datos internos incluyendo contabilidad. Afecta a servidor y datos internos.

Explotación remota desde el exterior.

Acceso a buzones de todos los usuarios

Posibilidad de modificar o falsificar correos (suplantación).

Impacto en disponibilidad global de mensajería y sistemas dependientes.

Exploit público disponible en exploit-db

About FIRST
Membership
Initiatives
Standards & Publications
Events
Education
Blog



Common Vulnerability Scoring System Version 4.0 Calculator

CVSS4.0/AV:N/AC:L/AT:N/PR:N/UI:N/VC:H/VI:H/VA:H/SC:H/SH:SA/L/EA:CR:H/IR:H/AR:M/MAV:N/MAC:L/MAT:N/MPR:N/MUI:N/MVCH/MVH/MVAH/MSC:H/MSL:H/MSAH/AU:Y/RE:M/U:Red
Reset

CVSS v4.0 Score: 10 / Critical

Base Metrics ?

Attack Vector (AV):	Network (N)	Adjacent (A)	Local (L)	Physical (P)
Attack Complexity (AC):	Low (L)	High (H)		
Attack Requirements (AT):	None (N)	Present (P)		
Privileges Required (PR):	None (N)	Low (L)	High (H)	
User Interaction (UI):	None (N)	Passive (P)	Active (A)	

Vulnerable System Impact Metrics

Confidentiality (VC):	High (H)	Low (L)	None (N)
Integrity (VI):	High (H)	Low (L)	None (N)
Availability (VA):	High (H)	Low (L)	None (N)

Subsequent System Impact Metrics

Confidentiality (SC):	High (H)	Low (L)	None (N)
Integrity (SI):	High (H)	Low (L)	None (N)
Availability (SA):	High (H)	Low (L)	None (N)

Supplemental Metrics ?

Safety (S):	Not Defined (X)	Negligible (N)	Present (P)		
Automatable (AU):	Not Defined (X)	No (N)	Yes (Y)		
Recovery (R):	Not Defined (X)	Automatic (A)	User (U)	Irrecoverable (I)	
Value Density (V):	Not Defined (X)	Diffuse (D)	Concentrated (C)		
Vulnerability Response Effort (RE):	Not Defined (X)	Low (L)	Moderate (M)	High (H)	
Provider Urgency (U):	Not Defined (X)	Clear	Green	Amber	Red

About FIRST
Membership
Initiatives
Standards & Publications
Events
Education
Blog



Common Vulnerability Scoring System Version 4.0 Calculator

CVSS4.0/AV:N/AC:L/AT:N/PR:N/UI:N/VC:H/VI:H/VA:H/SC:H/SH:SA/L/EA:CR:H/IR:H/AR:M/MAV:N/MAC:L/MAT:N/MPR:N/MUI:N/MVCH/MVH/MVAH/MSC:H/MSL:H/MSAH/AU:Y/RE:M/U:Red
Reset

CVSS v4.0 Score: 10 / Critical

Environmental (Modified Base Metrics) ?

Attack Vector (MAV):	Not Defined (X)	Network (N)	Adjacent (A)	Local (L)	Physical (P)
Attack Complexity (MAC):	Not Defined (X)	Low (L)	High (H)		
Attack Requirements (MAT):	Not Defined (X)	None (N)	Present (P)		
Privileges Required (MPR):	Not Defined (X)	None (N)	Low (L)	High (H)	
User Interaction (MUI):	Not Defined (X)	None (N)	Passive (P)	Active (A)	

Vulnerable System Impact Metrics

Confidentiality (MVC):	Not Defined (X)	High (H)	Low (L)	None (N)
Integrity (MVI):	Not Defined (X)	High (H)	Low (L)	None (N)
Availability (MVA):	Not Defined (X)	High (H)	Low (L)	None (N)

Subsequent System Impact Metrics

Confidentiality (MSC):	Not Defined (X)	High (H)	Low (L)	Negligible (N)
Integrity (MSI):	Not Defined (X)	High (H)	Low (L)	Negligible (N)
Availability (MSA):	Not Defined (X)	High (H)	Low (L)	Negligible (N)

Environmental (Security Requirements) ?

Confidentiality Requirements (CR):	Not Defined (X)	High (H)	Medium (M)	Low (L)
Integrity Requirements (IR):	Not Defined (X)	High (H)	Medium (M)	Low (L)
Availability Requirements (AR):	Not Defined (X)	High (H)	Medium (M)	Low (L)

Threat Metrics ?

Exploit Maturity (E):	Not Defined (X)	Attacked (A)	POC (P)	Unreported (U)
-----------------------	-----------------	--------------	---------	----------------

SQL Injection en aplicación web

Permite leer datos internos incluyendo contabilidad. Afecta a servidor y datos internos.

La aplicación web está expuesta en Internet.

Patrón de inyección clásico; fácil de explotar una vez autenticado.

Capacidad para leer datos sensibles (contabilidad).

No compromete disponibilidad de otros sistemas.

Vulnerabilidad no conocida públicamente; fue descubierta en la auditoria y requiere autenticación

About FIRST
Membership
Initiatives
Standards & Publications
Events
Education
Blog


Common Vulnerability Scoring System Version 4.0 Calculator

CVSS:4.0/AV:N/AC:L/AT:N/PR:L/UI:N/VC:H/VH:VA:L/SC:H/SL:SAN:EP:CR:H/IR:H/AR:M/MVCH/MVEL/MVAN/MSCH/MSEL/AU:Y/V:C/REM:U/Red
Reset

CVSS v4.0 Score: 7.1 / High

Base Metrics

Exploitability Metrics

Attack Vector (AV):	Network (N)	Adjacent (A)	Local (L)	Physical (P)
Attack Complexity (AC):	Low (L)	High (H)		
Attack Requirements (AT):	None (N)	Present (P)		
Privileges Required (PR):	None (N)	Low (L)	High (H)	
User Interaction (UI):	None (N)	Passive (P)	Active (A)	

Vulnerable System Impact Metrics

Confidentiality (VC):	High (H)	Low (L)	None (N)
Integrity (VI):	High (H)	Low (L)	None (N)
Availability (VA):	High (H)	Low (L)	None (N)

Subsequent System Impact Metrics

Confidentiality (SC):	High (H)	Low (L)	None (N)
Integrity (SI):	High (H)	Low (L)	None (N)
Availability (SA):	High (H)	Low (L)	None (N)

Supplemental Metrics

Safety (S):	Not Defined (D)	Negligible (N)	Present (P)		
Automatable (AU):	Not Defined (D)	No (N)	Yes (Y)		
Recovery (R):	Not Defined (D)	Automatic (A)	User (U)	Irrecoverable (I)	
Value Density (V):	Not Defined (D)	Diffuse (D)	Concentrated (C)		
Vulnerability Response Effort (RE):	Not Defined (D)	Low (L)	Moderate (M)	High (H)	
Provider Urgency (U):	Not Defined (D)	Clear	Green	Amber	Red

About FIRSTMembershipInitiativesStandards & PublicationsEventsEducationBlog

CVSS
Common Vulnerability Scoring System Version 4.0 Calculator
CVSS-4.0/AV:N/AC:L/AT:N/PR:L/UI:N/VC:H/V:L/VA:L/SC:H/SH:SAN/EP:CR:H/IR:H/AR:M/MVCH/MVL/MVA:N/MSCH/MSH/AU:Y/V:C/REM/U:Red
Reset
CVSS v4.0 Score: 7.1 / High

Environmental (Modified Base Metrics)

Exploitability Metrics

Attack Vector (MAV):	Not Defined (0)	Network (N)	Adjacent (A)	Local (L)	Physical (P)
Attack Complexity (MAC):	Not Defined (0)	Low (L)	High (H)		
Attack Requirements (MAT):	Not Defined (0)	None (N)	Present (P)		
Privileges Required (MPR):	Not Defined (0)	None (N)	Low (L)	High (H)	
User Interaction (MUI):	Not Defined (0)	None (N)	Passive (P)	Active (A)	

Vulnerable System Impact Metrics

Confidentiality (MVC):	Not Defined (0)	High (H)	Low (L)	None (N)
Integrity (MVI):	Not Defined (0)	High (H)	Low (L)	None (N)
Availability (MVA):	Not Defined (0)	High (H)	Low (L)	None (N)

Subsequent System Impact Metrics

Confidentiality (MSC):	Not Defined (0)	High (H)	Low (L)	Negligible (N)
Integrity (MSI):	Not Defined (0)	Safety (S)	High (H)	Low (L)
Availability (MSA):	Not Defined (0)	Safety (S)	High (H)	Low (L)

Environmental (Security Requirements)

Confidentiality Requirements (CR):	Not Defined (0)	High (H)	Medium (M)	Low (L)
Integrity Requirements (IR):	Not Defined (0)	High (H)	Medium (M)	Low (L)
Availability Requirements (AR):	Not Defined (0)	High (H)	Medium (M)	Low (L)

Threat Metrics

Exploit Maturity (E):	Not Defined (0)	Attacked (A)	POC (P)	Unreported (U)
-----------------------	-----------------	--------------	---------	----------------

Ejecución remota en FTP interno

Permite control total del servidor y pivotar a red de administración. Afecta a servidor.

Para cada vulnerabilidad se seleccionan las métricas CVSS justificando impacto y vector, considerando acceso, complejidad, privilegios y consecuencias sobre confidencialidad, integridad y disponibilidad.

Sólo explotable desde la red interna o desde una subred.

Acceso a subred de administración y datos críticos.

Podría tumbar servicios o modificar operaciones críticas.

Tiene impacto sobre servicios administrados.

Existe PoC, pero no exploit público el auditor la adaptó para explotar.

About FIRST
Membership
Initiatives
Standards & Publications
Events
Education
Blog


Common Vulnerability Scoring System Version 4.0 Calculator

CVSS:4.0/AV:A/AC:L/AT:N/PR:N/UI:N/VC:H/VI:H/VA:H/SC:H/SH/SA:H/EP:CR:H/IR:H/AR:H/MAV:A/MAC:L/MAT:N/MPR:N/MUI:N/MVC:H/MV:H/MVA:H/MSC:H/MS:H/MSA:H/AU:N/R:U/RE:M/U:Amber
Reset

CVSS v4.0 Score: 8.6 / High

Attack Vector (AV):
Network (N)
Adjacent (A)
Local (L)
Physical (P)

Attack Complexity (AC):
Low (L)
High (H)

Attack Requirements (AT):
None (N)
Present (P)

Privileges Required (PR):
None (N)
Low (L)
High (H)

User Interaction (UI):
None (N)
Passive (P)
Active (A)

Confidentiality (VC):
High (H)
Low (L)
None (N)

Integrity (VI):
High (H)
Low (L)
None (N)

Availability (VA):
High (H)
Low (L)
None (N)

Confidentiality (SC):
High (H)
Low (L)
None (N)

Integrity (SI):
High (H)
Low (L)
None (N)

Availability (SA):
High (H)
Low (L)
None (N)

Supplemental Metrics ?

Safety (S):
Not Defined (D)
Negligible (N)
Present (P)

Automatable (AU):
Not Defined (D)
No (N)
Yes (Y)

Recovery (R):
Not Defined (D)
Automatic (A)
User (U)
Irrecoverable (I)

Value Density (V):
Not Defined (D)
Diffuse (D)
Concentrated (C)

Vulnerability Response Effort (RE):
Not Defined (D)
Low (L)
Moderate (M)
High (H)

Provider Urgency (U):
Not Defined (D)
Clear
Green
Amber
Red

About FIRST
Membership
Initiatives
Standards & Publications
Events
Education
Blog


Common Vulnerability Scoring System Version 4.0 Calculator

CVSS:4.0/AV:A/AC:L/AT:N/PR:N/UI:N/VC:H/VI:H/VA:H/SC:H/SH/SA:H/EP:CR:H/IR:H/AR:H/MAV:A/MAC:L/MAT:N/MPR:N/MUI:N/MVC:H/MV:H/MVA:H/MSC:H/MS:H/MSA:H/AU:N/R:U/RE:M/U:Amber
Reset

CVSS v4.0 Score: 8.6 / High

Attack Vector (MAV):
Not Defined (D)
Network (N)
Adjacent (A)
Local (L)
Physical (P)

Attack Complexity (MAC):
Not Defined (D)
Low (L)
High (H)

Attack Requirements (MAT):
Not Defined (D)
None (N)
Present (P)

Privileges Required (MPR):
Not Defined (D)
None (N)
Low (L)
High (H)

User Interaction (MUI):
Not Defined (D)
None (N)
Passive (P)
Active (A)

Confidentiality (MVC):
Not Defined (D)
High (H)
Low (L)
None (N)

Integrity (MVI):
Not Defined (D)
High (H)
Low (L)
None (N)

Availability (MVA):
Not Defined (D)
High (H)
Low (L)
None (N)

Confidentiality (MSC):
Not Defined (D)
High (H)
Low (L)
Negligible (N)

Integrity (MSI):
Not Defined (D)
Safety (S)
High (H)
Low (L)
Negligible (N)

Availability (MSA):
Not Defined (D)
Safety (S)
High (H)
Low (L)
Negligible (N)

Confidentiality Requirements (CR):
Not Defined (D)
High (H)
Medium (M)
Low (L)

Integrity Requirements (IR):
Not Defined (D)
High (H)
Medium (M)
Low (L)

Availability Requirements (AR):
Not Defined (D)
High (H)
Medium (M)
Low (L)

Threat Metrics ?

Exploit Maturity (E):
Not Defined (D)
Attacked (A)
POC (P)
Unreported (U)